

Hunter 관리자 가이드

버전 1.3.0 · 한국어 · 최종 갱신 2026-09-12

이 문서는 사내 폐쇄망에서 Hunter를 설치하고 인증, 권한, 연동, 진단 정책, AI와 운영 데이터를 관리하는 절차를 설명합니다.

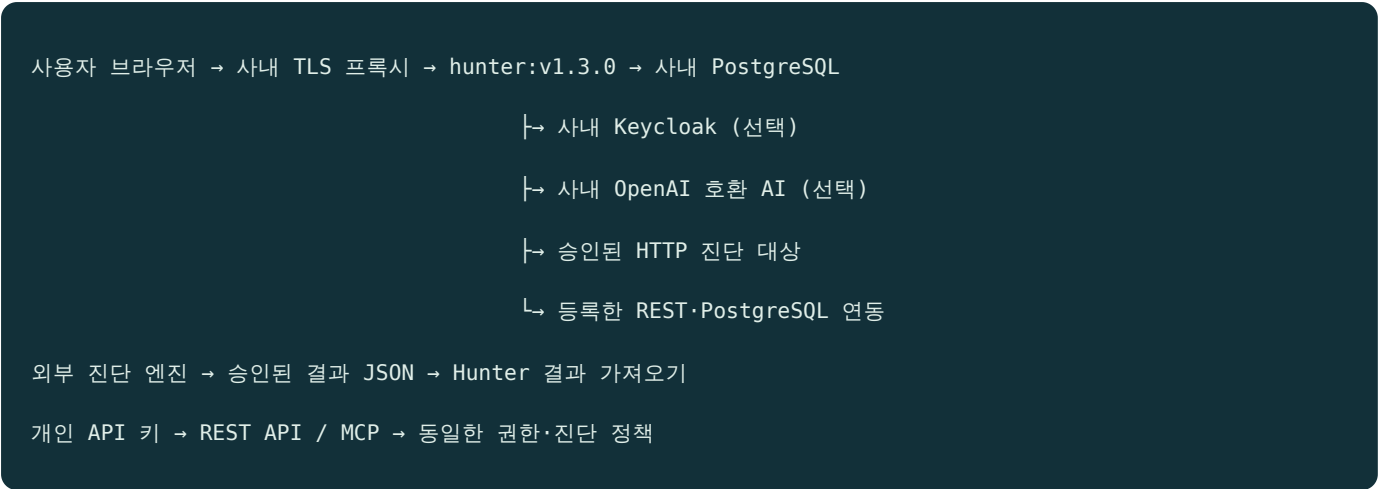
[프로젝트 소개](#) · [사용자 가이드](#) · [HTML](#) · [PDF](#) · [전체 화면](#)

화면은 실제 애플리케이션을 캡처했습니다. 예시 자산과 발견 건은 문서용 데이터이며 신규 설치 시 자동 생성되지 않습니다. 아래 제공 범위와 확장 범위를 구분하여 운영하세요. 에이전트 화면은 로컬 SSE 모의 모델과 실제 Hunter UI로 검증한 예시이며 실제 모델 품질·취약점 탐지 성능의 검증 결과가 아닙니다.

1. 아키텍처와 제공 범위

1.1 구성

Hunter 서비스 이미지에는 Go API 서버, React + Mantine 화면, 로컬 UI 자산과 내장 제한 진단 워크가 포함됩니다. PostgreSQL은 조직이 별도 운영합니다. 앱 서버는 8080 포트에서 API와 정적 화면을 함께 제공합니다.



운영 데이터는 PostgreSQL에 저장합니다. 설정 비밀정보와 증거의 암호화에 `ENCRYPTION_KEY` 를 사용하고, 비밀번호는 bcrypt 해시, 개인 API 키는 SHA-256 해시로 보관합니다. 서비스 이미지는 비특권 사용자로 실행하며 Docker 소켓이나 임의 명령 실행 인터페이스를 노출하지 않습니다.

1.2 현재 버전에서 실제 제공하는 기능

영역	제공 내용
자산	서비스 카탈로그, 환경·망·담당자·중요도·관련 대상, 발견 후보
인증	로컬 관리자·사용자, Keycloak OIDC discovery, 세션
권한	역할별 변경 가능한 기능 권한, 사용자·서비스 범위, 개인 키
진단	제한된 HTTP 보안 헤더 검사, 읽기 전용 합성 데이터 권한 비교
통제	서비스 승인, 유효 범위, 요청률·시간·요청 수 제한, 긴급 중지
작업	PostgreSQL 기반 작업 큐, 임대·생존 확인·취소, 변경 이벤트, 주기적 예약, 망별 워크
결과	수동 등록, Nuclei·Trivy·ZAP·SARIF·Gitleaks JSON 수입, 중복 관찰
업무	발견 건 상태, 사유·만료가 있는 위험 수용, 지원되는 재검증
연동	REST 수집, 읽기 전용 PostgreSQL 수집, 웹훅, API
관계·보고	등록 데이터 관계 그래프, 위험 현황, JSON·CSV 내보내기
AI	OpenAI 호환 API, 기본 SSE 스트리밍, 모델·토큰 설정

영역	제공 내용
에이전트	PentAGI MIT 코어, Hunter 도구 기반 계획·위임·실행, 실시간 이력과 중지
개발자 도구	OpenAPI 명세, 개인 Bearer 키를 사용하는 HTTP MCP
참여	발견 건 기여 점수와 집계, 현금 보상 자동 지급 제외

목록·보고서·대시보드·관계 그래프는 접근 가능한 자료를 종류별 생성 시각 기준 최신 5,000건까지 조회·집계합니다. 목록 화면은 조회한 범위 안에서 검색·필터·정렬·페이지 이동을 제공합니다. 이 한도를 넘는 서버 전체 이력 집계와 추가 페이지 조회는 현재 버전에 포함되지 않으며, 규모 확장 시 별도 구현이 필요합니다.

1.3 별도 확장이 필요한 영역

같은 서비스 이미지를 워커 전용 모드로 망별 배치할 수 있습니다. 진단 컨테이너를 동적으로 생성하는 실행 플랫폼, 외부 스캐너 바이너리, 브라우저 회귀 테스트 실행기, Kubernetes·DNS·Harbor 전용 discovery 클라이언트는 번들하지 않습니다. 제공된 REST·DB 수집과 API를 사내 시스템에 맞게 연결하는 형태입니다.

전체 소스의 AI 자동 분석, 의미 기반 오탐 확정과 공통 원인 자동 병합, 자동 코드 수정·병합, 메신저 전용 봇, Canary 대규모 배포, 조직 평판·보상 지급, 전체 업무 역할 매트릭스 자동 생성은 후속 확장 영역입니다. 그래프는 등록된 관계를 보여주며 전사 공격 경로를 자동 증명하지 않습니다. 개선 초안은 설정한 외부 REST API로 명시적으로 발송할 수 있습니다.

외부 스캐너·브라우저의 직접 네트워크 통신을 Hunter가 통제한다고 가정해서는 안 됩니다. 해당 도구의 실행 환경, 접근 통제, 오프라인 규칙·취약점 DB 반입과 갱신은 조직에서 별도로 운영합니다.

2. 설치 전 준비

준비 항목	요구 사항
실행 서버	Linux amd64, Docker Engine 및 Compose v2
PostgreSQL	사내 운영 PostgreSQL, Hunter 전용 DB·계정, 스키마 생성·변경 권한
네트워크	Hunter → PostgreSQL 및 선택한 사내 인증·AI·연동 대상
사용자 접속	사내 DNS 이름과 HTTPS 종단 프록시 권장
관리자 정보	초기 관리자 ID, 고유한 12~72바이트 비밀번호
암호화 키	무작위 32바이트의 base64 인코딩 값
반입 파일	릴리즈의 <code>hunter-v1.3.0.tar.gz</code> , <code>compose.yaml</code> , <code>.env.example</code>
백업	DB 백업과 암호화 키를 분리하여 안전하게 보관할 위치

서비스 자원은 사용량에 따라 산정합니다. 시작점으로 2 vCPU와 2~4 GiB 메모리를 두고 실제 응답 지연, 연결 수, 진단량에 따라 조정할 수 있으나, 이는 성능 검증 수치나 용량 보장이 아닙니다. 연결한 AI 모델의 메모리·가속기 자원은 Hunter 서버와 별개입니다.

브라우저가 접근하는 주소와 서버가 접근하는 주소를 구분합니다. 컨테이너 안의 `localhost` 는 Hunter 컨테이너 자신입니다. 사내 DB 또는 Keycloak 호스트 주소를 사용합니다.

3. 오프라인 배포

3.1 릴리즈 파일 검증과 반입

인터넷이 허용된 구간에서 GitHub 릴리즈의 서비스 이미지 압축 파일을 내려받습니다. 릴리즈 본문에 표시된 SHA-256과 비교한 뒤 조직의 반입 절차를 따릅니다.

```
sha256sum hunter-v1.3.0.tar.gz  
gzip --test hunter-v1.3.0.tar.gz
```

첨부 자산은 `hunter-v버전.tar.gz` 한 개이며 내부 이미지 이름은 `hunter:v버전` 입니다. PostgreSQL 이미지나 문서 PDF는 릴리즈 첨부 자산에 포함하지 않습니다. GitHub가 자동 표시하는 소스 코드 ZIP·TAR 다운로드는 사용자 첨부 자산과 별개입니다.

3.2 네 가지 환경변수 설정

운영 디렉터리에 `compose.yaml` 과 `.env.example` 을 복사하고 다음 명령으로 환경 파일을 준비합니다.

```
cp .env.example .env  
chmod 600 .env  
openssl rand -base64 32
```

생성한 암호화 키를 `.env` 에 넣고 다음 네 값을 모두 실제 정보로 바꿉니다. 이 파일을 Git에 커밋하지 않습니다.

```
POSTGRES_DSN=postgres://hunter:URL_ENCODED_PASSWORD@postgres.internal:5432/hunter?sslmode=verify-full  
BOOTSTRAP_ADMIN=admin  
BOOTSTRAP_ADMIN_PASSWORD=A_UNIQUE_LONG_BOOTSTRAP_PASSWORD  
ENCRYPTION_KEY=BASE64_ENCODED_32_RANDOM_BYTES
```

환경변수	의미	운영 시 유의 사항
POSTGRES_DSN	PostgreSQL 연결 문자열	비밀번호의 특수문자는 URL 인코딩, TLS 정책 적용
BOOTSTRAP_ADMIN	처음 생성할 로컬 관리자 아이디	사용자가 전혀 없는 DB에서만 초기 생성
BOOTSTRAP_ADMIN_PASSWORD	초기 관리자 비밀번호	12~72바이트, 기존 계정 비밀번호를 덮어쓰지 않음

환경변수	의미	운영 시 유의 사항
ENCRYPTION_KEY	설정·증거 암호화 키	32바이트 base64, 기존 DB와 같은 키를 유지

런타임 설정용 환경변수는 위 네 가지입니다. 서비스명, 공개 주소, OIDC, AI, 세션, 권한, 연동과 진단 정책은 관리자 화면에서 저장합니다.

암호화 키를 재기동마다 생성하면 안 됩니다. 기존 DB에 다른 키를 제공하면 시작 검증이 실패합니다. 초기 관리자 환경변수를 바꾸는 것으로 기존 관리자 계정을 복구하거나 비밀번호를 바꿀 수 없습니다.

3.3 이미지 불러오기와 실행

```
docker load -i hunter-v1.3.0.tar.gz

docker image inspect hunter:v1.3.0

docker compose up -d

docker compose ps

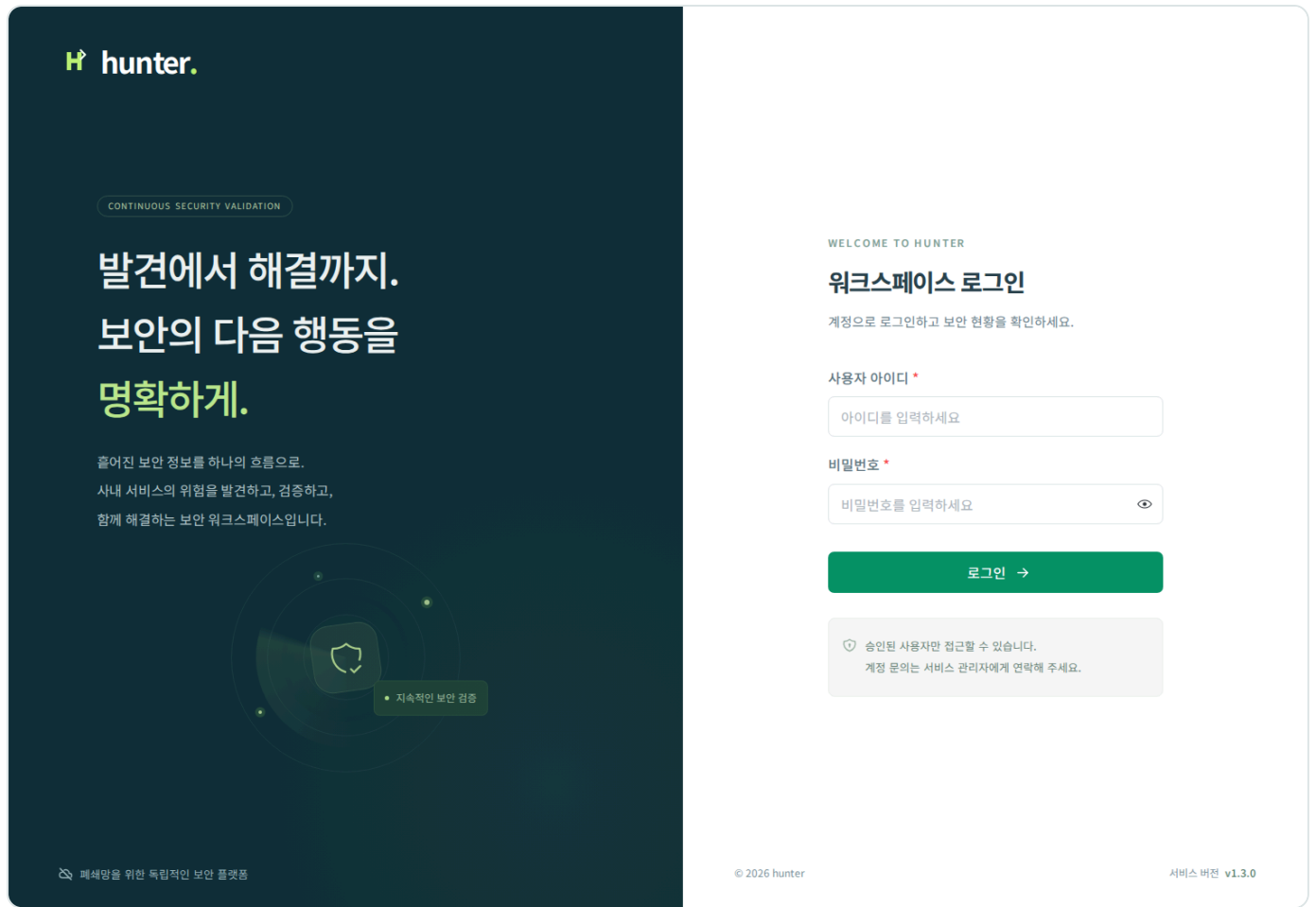
curl --fail http://localhost:8080/api/health
```

정상 상태 응답에는 상태와 버전이 포함됩니다. 오류가 있으면 `docker compose logs --tail=100 hunter` 로 원인을 확인합니다. DSN이나 비밀번호가 노출된 터미널 기록은 공유하지 마세요.

Compose는 `pull_policy: never` 로 자동 이미지 다운로드를 하지 않습니다. 루트 파일시스템은 읽기 전용이고 임시 공간은 제한된 tmpfs입니다. PostgreSQL은 Compose에 포함하지 않습니다.

3.4 최초 로그인

브라우저에서 `http://서버주소:8080` 또는 사내 HTTPS 주소에 접속해 초기 관리자 계정으로 로그인합니다. **개인화 → 내 프로필**에서 초기 비밀번호를 운영 비밀번호로 변경합니다.



다음 순서로 설정하면 연결 오류를 줄일 수 있습니다.

1. 서비스 외부 접근 주소와 서비스 이름
2. 사내 인증서 신뢰 설정과 HTTPS
3. OIDC 연결
4. 역할별 권한과 사용자
5. 서비스·진단 정책·허용 범위
6. 선택적 AI와 사내 자산 연동
7. 필요한 경우 팀장 검토·승인

4. HTTPS와 사내 인증서

사용자 접속은 사내 TLS 프록시에서 HTTPS로 종단하고 Hunter의 8080 포트로 전달합니다. 프록시는 `Host` 를 보존하고 AI 스트리밍 응답을 버퍼링하지 않도록 설정합니다. 공개 주소를 실제 HTTPS 주소로 저장하면 보안 쿠키 설정과 OIDC 리다이렉트에 사용됩니다.

Nginx를 사용하는 조직의 예시는 다음과 같습니다. 인증서 경로는 실제 운영 환경에 맞게 지정합니다.

```
server {  
    listen 443 ssl;  
  
    server_name hunter.internal;  
  
    ssl_certificate      /etc/nginx/certs/hunter.crt;  
    ssl_certificate_key  /etc/nginx/certs/hunter.key;  
  
    location / {  
        proxy_pass http://hunter:8080;  
        proxy_set_header Host $host;  
        proxy_set_header X-Forwarded-Proto https;  
        proxy_buffering off;  
        proxy_read_timeout 600s;  
        client_max_body_size 10m;  
    }  
}
```

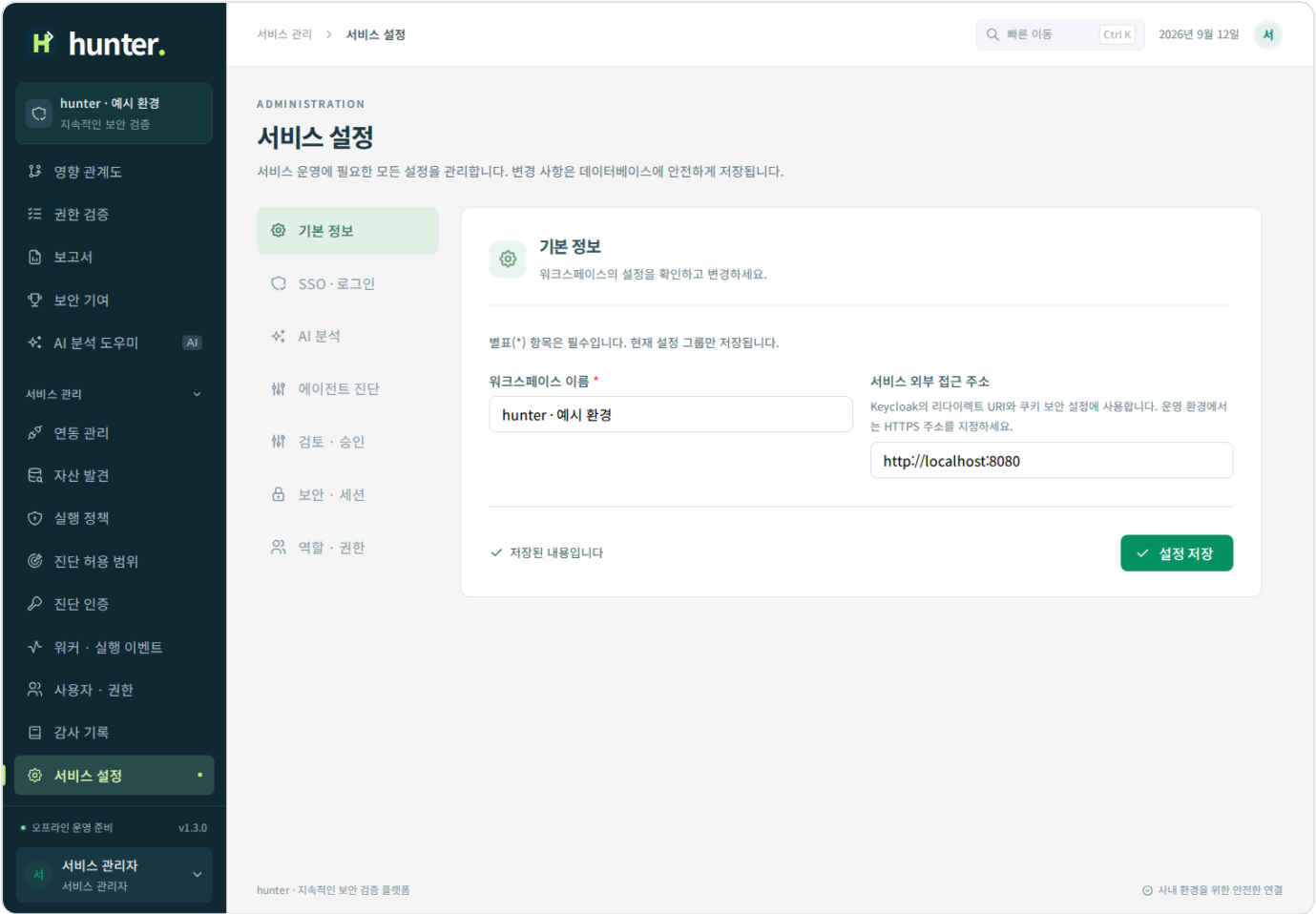
네트워크 구성에 따라 `hunter:8080` 은 실제 백엔드 주소로 변경합니다. 임의 외부 호스트의 forwarded 헤더를 신뢰하는 구성을 피하고 프록시 접근 경로를 통제합니다.

서비스에서 접근하는 사내 HTTPS 대상이 사설 CA를 사용하면 **서비스 설정 → 보안·세션 → 신뢰 CA**에 PEM 인증서를 등록합니다. 이 설정은 적용된 사내 HTTP 클라이언트의 신뢰 확장에 사용됩니다. 서버 자신의 HTTPS 인증서나 PostgreSQL 드라이버의 TLS 루트 인증서 설정과는 별개입니다.

PostgreSQL TLS는 DSN의 `sslmode=verify-full` 과 `sslrootcert=/경로/ca.pem` 등을 통해 구성합니다. 필요하면 CA 파일을 읽기 전용으로 마운트합니다. TLS 검증을 끄는 방식으로 인증서 문제를 우회하지 않습니다.

5. 서비스 전체 설정

관리자 → 서비스 설정에서 그룹별로 값을 저장합니다. 설정은 DB에 보관되며 일반적인 변경에 재배포가 필요하지 않습니다.



설정 그룹	주요 내용
기본 정보	서비스 이름, 외부 접근 주소
SSO·로그인	OIDC 활성화, Issuer, Client ID, Client Secret, 신규 계정 역할
AI 분석	활성화, Base URL, API 키, 모델, 최대 출력 토큰, 컨텍스트 창
에이전트 진단	활성화, 반복·모델·도구 한도, 제한 시간, 진단·후보·기억 허용
검토·승인	팀장 검토·승인 흐름 활성화
보안·세션	새 세션 유효 시간, 개인 키 최대 수명, 사내 신뢰 CA
역할·권한	팀장·분석가·열람자별 기능 권한

5.1 입력과 저장 상태 확인

별표(*)가 붙은 항목은 필수이며 **설정 저장**은 현재 그룹에만 적용됩니다. 폼 아래에 **저장된 내용입니다** , **저장하지 않은 변경 사항이 있습니다** , **저장 중입니다...** , 저장 완료 시각을 표시합니다. 값이 달라진 그룹은 설정 메뉴에서도 표시합니다.

필수값이나 URL·숫자 등의 형식이 잘못되면 폼 위의 오류 요약과 해당 입력 옆의 메시지를 확인합니다. 요약의 링크를 선택하면 문제가 있는 입력으로 이동합니다. 서버 저장 실패도 폼 안에 표시하며 입력값은 남아 있으므로 원인을 수정한 뒤 다시 저장할 수 있습니다. 성공 표시가 나타나기 전에 저장 완료로 판단하지 마세요.

5.2 저장하지 않은 설정 그룹 이동

현재 그룹을 변경한 상태에서 다른 설정 그룹을 선택하면 다음 중 하나를 고릅니다.

- **계속 수정:** 현재 그룹으로 돌아가 입력을 계속합니다.
- **입력 유지하고 이동:** 현재 입력을 저장하지 않고 화면에 보관한 채 다른 그룹을 확인합니다. 같은 설정 화면 안에서 돌아오면 입력을 이어갈 수 있습니다.
- **저장 후 이동:** 현재 그룹을 저장한 뒤 선택한 그룹으로 이동합니다. 저장에 실패하면 오류를 해결해야 합니다.

이 보관은 자동 저장이나 장기 초안 저장이 아닙니다. 브라우저 새로고침·탭 닫기에는 브라우저가 제공하는 미저장 경고가 표시될 수 있지만, 브라우저 정책과 사용자 조작에 따라 경고가 생략될 수 있습니다. 다른 업무 페이지로 떠나기 전에는 변경한 각 그룹을 직접 저장하세요.

관리 목록에는 상단 결과 수·적용 조건별 해제·저장 보기·표 표시 설정을 제공합니다. 저장 보기와 행 간격은 **현재 브라우저의 사용자·메뉴별 설정**이며 관리자가 조직 전체 설정을 바꾸는 기능과 다릅니다. 보기 적용 시 첫 페이지부터 표시하며, 이름·조회 조건만 저장하고 현재 계정의 권한을 그대로 적용합니다. 자세한 절차는 [사용자 가이드](#)를 참고하세요.

비밀 설정은 조회할 때 원문을 반환하지 않습니다. 저장된 표시로 여부를 확인하며 빈 입력은 기존 값을 유지합니다. API에서 명시적인 비밀 삭제 옵션을 제공하는 경우에만 삭제됩니다. 설정 화면의 일반 텍스트에 비밀번호를 넣지 않습니다. 설정·비밀번호 폼의 미저장 비밀값은 현재 화면의 메모리 초안이며 브라우저 저장 보기에 넣지 않습니다. 성공적으로 제출한 비밀 입력은 화면에서 비웁니다.

6. Keycloak OIDC SSO

6.1 Keycloak 클라이언트 준비

조직의 Keycloak realm에서 OpenID Connect 클라이언트를 생성합니다.

Keycloak 항목	설정 예시
Client ID	hunter
Client authentication	활성화
Standard flow	활성화
Valid redirect URIs	https://hunter.internal/api/auth/oidc/callback
Web origins	https://hunter.internal

정확한 필드 위치는 Keycloak 버전에 따라 다를 수 있습니다. 리다이렉트 URI는 와일드카드 대신 실제 Hunter 주소로 제한합니다. 생성된 Client Secret은 관리자 설정의 비밀 입력에만 저장합니다.

6.2 Hunter 설정

1. 기본 정보의 공개 주소를 `https://hunter.internal` 로 저장합니다.
2. SSO·로그인에 Issuer `https://keycloak.internal/realms/company` 를 입력합니다.
3. Client ID와 Client Secret을 입력합니다.
4. 신규 SSO 계정 기본 역할을 선택합니다. 일반적으로 열람자부터 시작합니다.
5. OIDC 사용을 켜고 저장합니다.
6. 별도 브라우저 세션에서 SSO 로그인을 검증합니다.
7. 생성된 사용자 역할을 필요 범위로 조정합니다.

Hunter는 Issuer에서 discovery 메타데이터와 서명키를 찾고 state, nonce, PKCE와 ID 토큰 검증을 사용합니다. Hunter 서버와 브라우저 모두 필요한 사내 Keycloak 주소에 접근할 수 있어야 합니다. 시스템 시간이 크게 어긋나면 토큰 검증에 실패할 수 있습니다.

SSO subject는 로컬 사용자명과 별도로 식별합니다. 임의로 같은 이메일이나 사용자명을 가진 계정에 관리자 권한을 자동 결합하는 방식으로 운영하지 않습니다. 로컬 관리자는 SSO 장애 시 별도 관리 접근 경로로 유지할 수 있습니다.

7. 사용자와 역할 권한

7.1 사용자 관리

서비스 관리 → 사용자 · 권한에서 사용자명, 표시 이름, 역할과 비활성화 여부를 관리합니다. 새 로컬 계정에는 12~72바이트의 초기 비밀번호를 지정합니다. 기존 사용자 수정 시 빈 비밀번호는 기존 값을 유지합니다.

사용자 목록의 검색창은 이름·아이디·조직·역할을 검색합니다. 역할·활성 상태·조직 필터를 함께 적용하고 열 제목으로 정렬한 뒤 페이지를 이동할 수 있습니다. **조건 초기화**는 검색·필터·정렬·페이지 조건을 기본 상태로 돌립니다. 조건은 URL에 보존되므로 새로고침과 뒤로가기 후에도 해당 조건을 확인할 수 있습니다.

서비스 관리 > 사용자 · 권한

IDENTITY & ACCESS

사용자 · 권한

서비스 사용자를 등록하고 역할과 계정 접근 상태를 관리합니다.

사용자 목록 1

이름 · 아이디 · 조직 · 역할 검색

모든 역할 | 모든 상태 | 모든 조직

1개 결과 / 조회 1개

열 제목을 눌러 정렬할 수 있습니다.

사용자	아이디	담당 조직	역할	상태	등록 일시	관리
서비스 관리자	admin 로컬 로그인	미지정	서비스 관리자	활성	09. 11. 오전 07:04	수정

1명 · 1-1 표시

25개씩

변경 가능한 역할 권한

역할별 기능 권한은 서비스 설정 → 역할 · 권한에서 변경할 수 있습니다. 계정 비활성화 시 해당 사용자의 접근과 개인 API 키 사용이 제한됩니다.

hunter · 지속적인 보안 검증 플랫폼

사내 환경을 위한 안전한 연결

사용자를 비활성화하면 해당 계정의 사용과 API 키 접근이 제한됩니다. 마지막 활성 관리자를 비활성화하거나 관리자 권한을 제거할 수 없습니다. 조직 내 퇴직·이동 절차와 계정 비활성화를 연결할 때 개인 키도 함께 확인합니다.

7.2 로그인 남용 방어

로컬 로그인은 서버가 확인한 연결 IP마다 1분 동안 최대 120회 시도를 허용하고, 사용자명과 IP 조합에는 기존 15분·10회 제한을 적용합니다. 비밀번호 검증 작업은 프로세스당 최대 4개를 동시에 처리합니다. 초과 요청은 429로 거부하여 무작위 사용자명으로 비밀번호 해시 연산을 무제한 유발하지 못하게 합니다.

사내 리버스 프록시 뒤에서는 여러 사용자의 접속이 같은 프록시 IP로 보일 수 있습니다. 이 경우 IP 한도를 함께 적용하므로 반복되는 429 오류를 조사할 때 실제 연결 경로를 확인합니다. 임의 forwarded 헤더를 받아 제한을 우회하게 하지 않습니다.

7.3 권한 목록

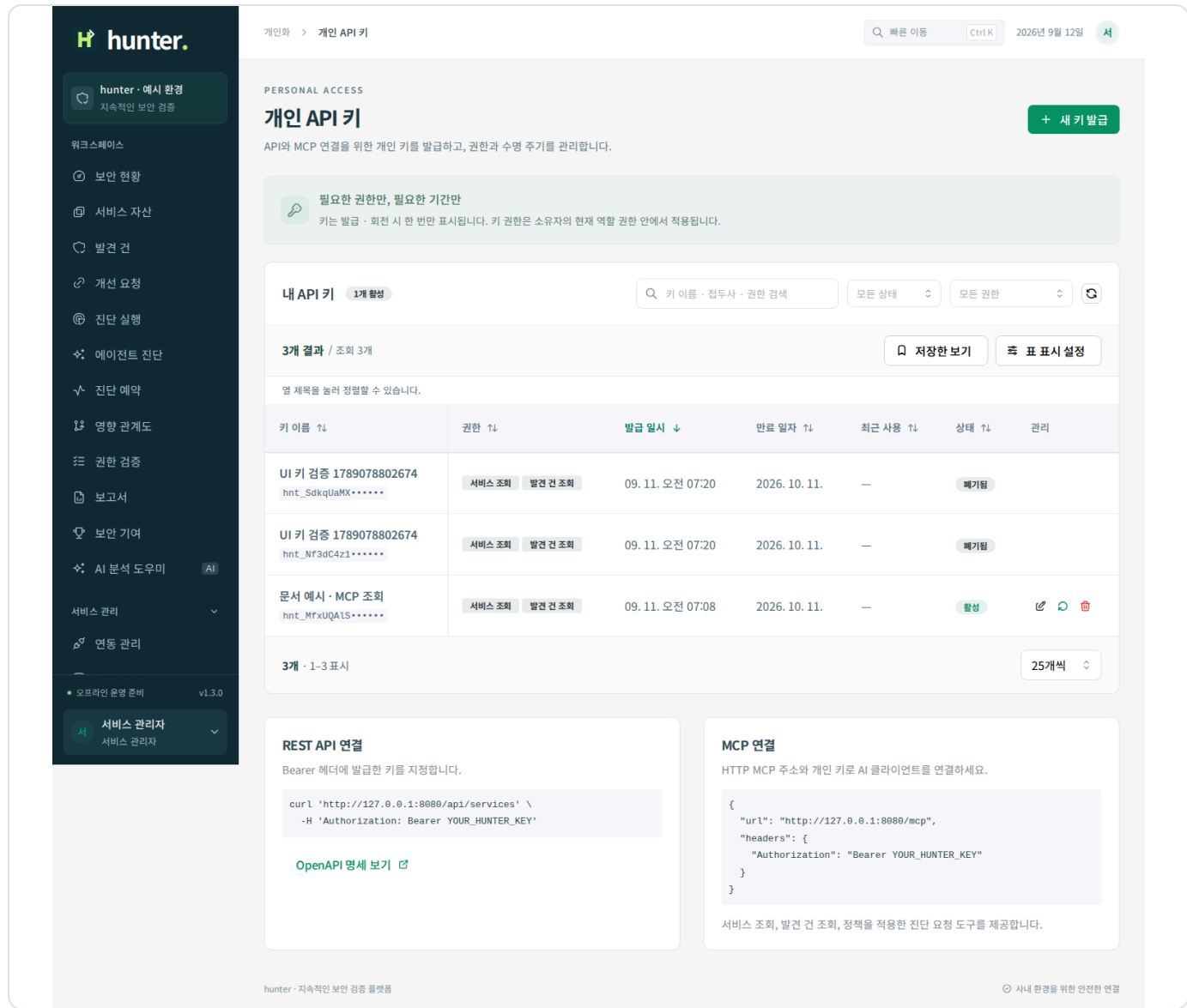
권한	기능
services:read	서비스와 연결된 업무 자료 조회
services:write	서비스·권한 시나리오 등 관리
findings:read	발견 건 조회
findings:write	발견 건 등록·수정·결과 수입
scans:read	진단 작업 조회
scans:write	진단 요청·취소
scans:approve	선택적 승인 흐름의 검토
integrations:manage	연동 설정과 자산 수집
admin:manage	서비스 전반 관리
audit:read	감사 기록 조회
ai:use	AI 분석 사용
agents:read	허용된 서비스의 에이전트 실행·이벤트 조회
agents:write	에이전트 실행 생성·중지·새 실행으로 재시도

관리자 역할은 전체 관리 권한을 유지합니다. 다른 역할은 서비스 설정에서 조정합니다. 역할 변경은 새 키를 발급하지 않아도 현재 계정과 개인 키의 실제 권한에 반영됩니다. 데이터 소유 범위는 기능 권한과 별도로 적용됩니다.

사용자 관리의 팀 값과 서비스의 팀 값으로 조직 접근 범위를 연결합니다. 팀장도 전체 조직의 데이터를 자동으로 열람하지 않으며 자신이 소유하거나 같은 팀에 속한 서비스 범위를 따릅니다. 복잡한 조직 계층·상속 ACL이 필요한 경우 별도 정책 확장을 검토합니다.

7.4 개인 키 운영 원칙

키는 개인화 페이지에서 소유자가 발급·수정·회전·폐기합니다. 관리자는 서비스 전체의 최대 유효 기간과 역할 권한을 설정합니다. 서버는 키 원문을 다시 보여주지 않습니다.



회전은 원자적으로 기존 키를 폐기하고 새 키를 발급합니다. 기존 연동이 즉시 끊기므로 전환 시점을 계획합니다. API 계정 권한을 축소하면 기존 키의 권한도 그 범위 안으로 줄어듭니다. 감사와 최근 사용 일시를 확인하여 미사용 키를 정리합니다.

8. 서비스 승인과 진단 허용 범위

8.1 서비스 승인

서비스 URL과 환경, 담당자를 확인한 뒤 서비스의 진단 승인 상태를 설정합니다. URL뿐 아니라 환경·망·조직·담당자·중요도·대상·저장소·이미지 또는 소유자 변경 시 기존 승인이 해제되므로 변경된 대상을 재확인합니다. 단순 자산 등록이나 discovery 후보 생성만으로 진단은 실행되지 않습니다.

8.2 허용 범위

관리자 → 진단 허용 범위에서 서비스마다 범위를 등록합니다.

hunter.

hunter · 예시 환경
지속적인 보안 검증

발견 건

개선 요청

진단 실행

에이전트 진단

진단 예약

영향 관계도

권한 검증

보고서

보안 기여

AI 분석 도우미

서비스 관리

연동 관리

자산 발견

실행 정책

진단 허용 범위

오프라인 운영 준비

서비스 관리자

서비스 관리 > 진단 허용 범위

빠른 이동 Ctrl K

2026년 9월 12일

서

ADMINISTRATION

진단 허용 범위

승인된 호스트, 경로, 유효 기간을 명시하여 진단 대상의 경계를 지킵니다.

허용 범위 목록 6

이름, 서비스, 상태 검색

대상 서비스

전체

6개 결과 / 조회 6개

저장한 보기

표 표시 설정

열 제목을 눌러 정렬할 수 있습니다.

이름 ↑	대상 서비스 ↑	허용 호스트 ↑	만료 일시 ↑	진단 승인 ↑
NL2SQL 스튜디오 검증 범위	NL2SQL 스튜디오	nl2sql.example.internal	10. 11. 오전 07:08	승인됨
개발자 포털 검증 범위	개발자 포털	developer.example.internal	10. 11. 오전 07:08	승인됨
Harbor 레지스트리 검증 범위	Harbor 레지스트리	harbor.example.internal	10. 11. 오전 07:08	승인됨
API 게이트웨이 검증 범위	API 게이트웨이	gateway.example.internal	10. 11. 오전 07:08	승인됨
사내 AI 포털 검증 범위	사내 AI 포털	ai.example.internal	10. 11. 오전 07:08	승인됨
ITSM 업무 포털 검증 범위	ITSM 업무 포털	itsm.example.internal	10. 11. 오전 07:08	승인됨

6건 · 1-6 표시

25개씩

hunter · 지속적인 보안 검증 플랫폼

사내 환경을 위한 안전한 연결

항목	설정 원칙
대상 서비스	실제 승인한 서비스
허용 호스트	명시적인 호스트·포트, 전체 와일드카드 지양
허용 경로	읽기 전용의 필요한 접두 경로
허용 CIDR	DNS가 해석할 수 있는 승인 IP 대역 제한

항목	설정 원칙
만료 일시	승인 기간의 종료 시각
최대 RPS	대상과 공유 백엔드가 감당할 요청률
최대 요청 수	한 작업의 총 요청 예산
시간 제한	작업이 실행될 수 있는 최대 시간
승인 여부	담당 조직의 진단 허가를 확인한 후 활성화

요청량을 작게 시작하고 진단 전후 대상 시스템의 실제 지연·오류를 확인합니다. RPS 1이 모든 운영계에서 안전함을 보장하지 않습니다. DNS 결과, 리다이렉트와 경로 검사에서 거부된 요청은 허용 범위를 무조건 넓히기보다 실제 필요한 경로인지 먼저 확인합니다.

9. 실행 정책과 긴급 중지

관리자 → 실행 정책에서 기본 통제를 관리합니다. 활성화된 정책의 제한은 진단 요청에 적용됩니다. 허용 메서드는 지원되는 읽기 전용 GET·HEAD 범위에서 사용하고, 삭제·결제·발송·승인 같은 업무 경로를 차단합니다.

hunter.

hunter · 예시 환경
지속적인 보안 검증

서비스 자산

발견 건

개선 요청

진단 실행

에이전트 진단

진단 예약

영향 관계도

권한 검증

보고서

보안 기여

AI 분석 도우미

서비스 관리

연동 관리

자산 발견

실행 정책

오프라인 운영 준비

서비스 관리자

서비스 관리 > 실행 정책

빠른 이동 Ctrl K 2026년 9월 12일 서

ADMINISTRATION

실행 정책

요청량, 허용 메서드, 차단 경로 등 모든 진단의 안전 기준을 정의합니다.

정책 목록 1

이름, 서비스, 상태 검색

1개 결과 / 조회 1개

저장한 보기

표 표시 설정

열 제목을 눌러 정렬할 수 있습니다.

이름 ↑	최대 RPS ↑	최대 요청 ↑	제한 시간 ↑	사용 ↑
업무량 기본 안전 정책	1	10	30	활성

1건 · 1-1 표시

25개씩

정책 JSON 다운로드

정책 등록

hunter · 지속적인 보안 검증 플랫폼

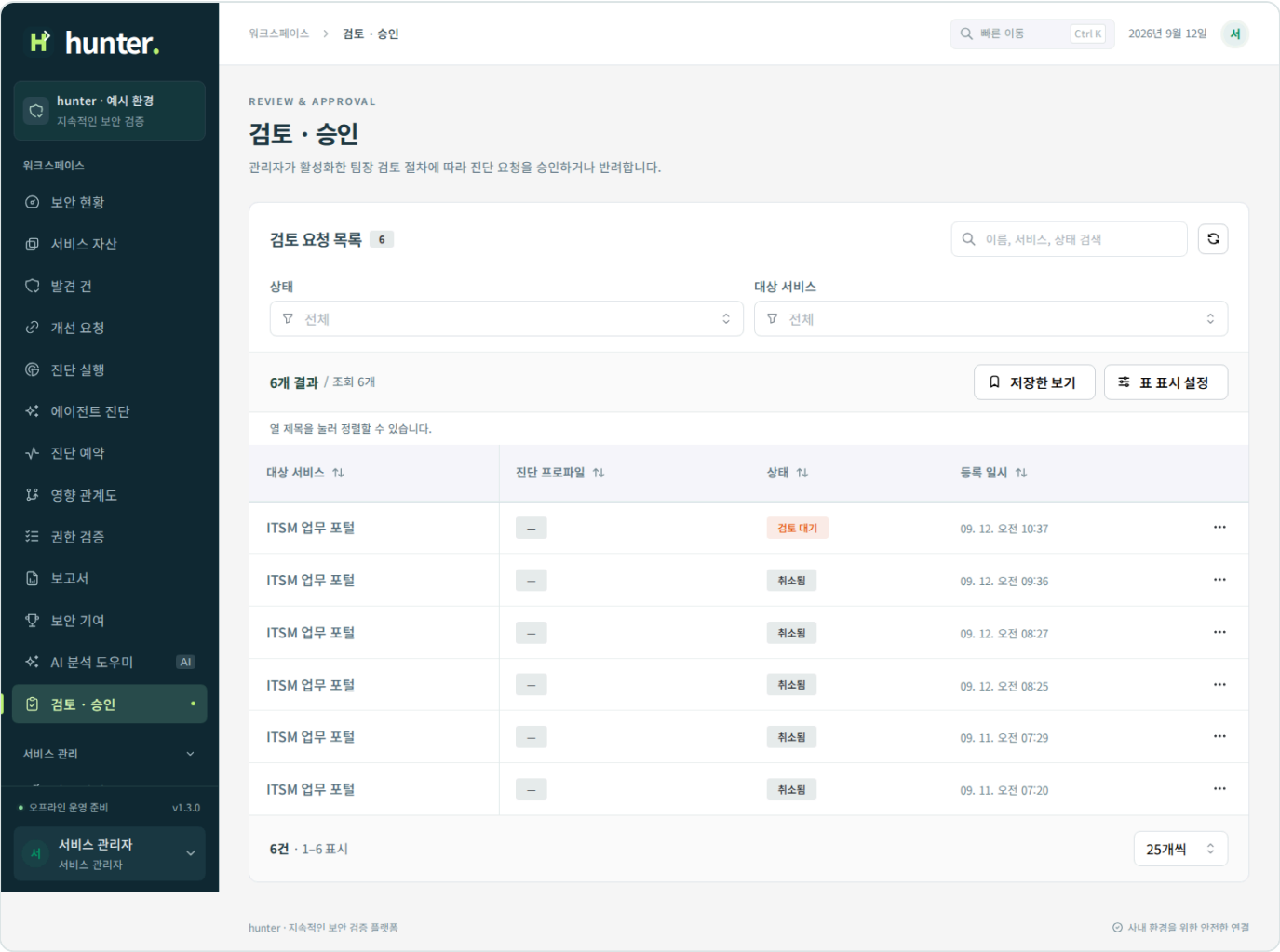
사내 환경을 위한 안전한 연결

운영계에 임의의 능동 공격 프로파일을 제공하지 않습니다. 관리자가 더 큰 숫자를 입력해도 실제 구현된 프로파일과 서버의 상한을 넘는 엔진이 생성되지 않습니다. UI의 JSON 입력과 API로 정책을 저장하고, 사내 Git 저장소에서 JSON 변경 이력을 별도로 관리할 수 있습니다. YAML·Rego 실행 엔진을 내장한 것은 아닙니다.

긴급 중지는 신규 작업과 진행 중 진단을 중단하는 운영 통제입니다. 원인을 기록하고 범위·서비스 상태를 점검한 뒤 해제합니다. 네트워크 워커의 요청 예산과 응답 오류·지연 제한을 적용하며, 모든 사내 모니터링 제품의 CPU·DB 지표를 자동 구독하지는 않습니다. 조직의 모니터링 경보는 API 연동으로 중지 요청을 연결할 수 있습니다.

10. 선택적 검토·승인 프로세스

서비스 설정의 검토·승인 → 팀장 검토·승인 프로세스 사용으로 켜거나 끕니다. 기본값은 비활성화입니다.

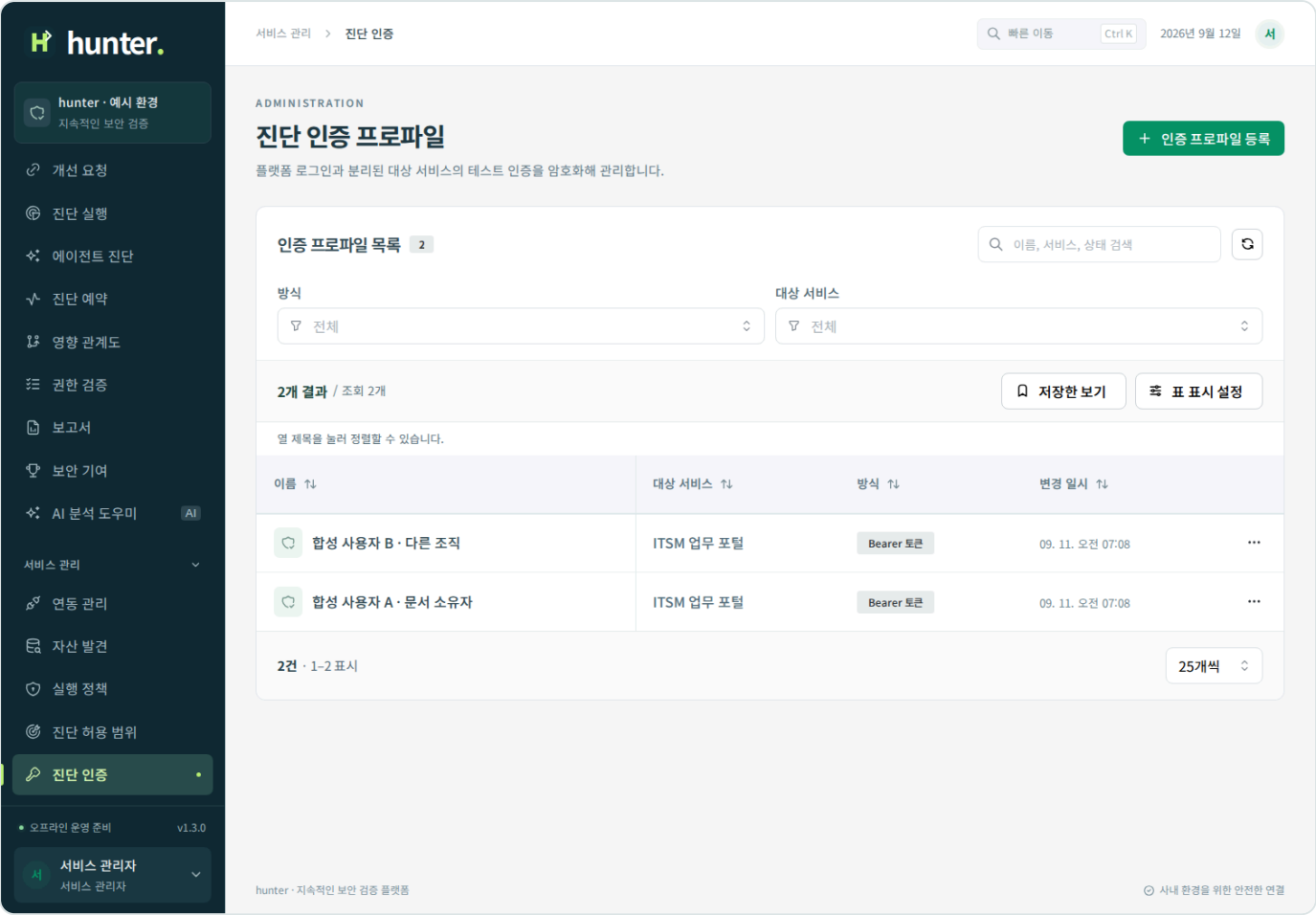


상태	사용자 경험
비활성화	승인 메뉴와 업무 단계 제외, 동일한 실행 정책 확인 후 진단
활성화	진단 요청이 검토 대상으로 생성되고 권한 있는 검토자가 승인·반려
승인 후 범위 만료	실제 실행 전 정책 검사에서 거부
실행 중 긴급 중지	작업을 취소하고 중단 상태 기록

팀장 검토 설정과 대상의 법적·업무상 진단 허가는 별개입니다. 승인 옵션을 끄는 것으로 임의 주소나 외부 서비스에 진단할 권한이 생기지 않습니다. 위험 수용·오탐 처리도 활성화 시 팀장 또는 관리자 판단을 요구합니다.

11. 진단 대상 인증 프로파일

관리자 → 인증 프로파일에서 진단 대상 서비스의 테스트 인증 정보를 관리합니다. Hunter 플랫폼 로그인과 테스트 대상 인증은 서로 다릅니다.



지원 방식은 Bearer, Basic, 사용자 지정 헤더입니다. 프로파일마다 대상 서비스를 지정하고 별도의 테스트 계정을 사용합니다. 비밀번호는 암호화하여 보관하고 일반 조회에서 원문을 노출하지 않습니다.

권한 시나리오에는 같은 서비스에 연결된 서로 다른 두 프로파일이 필요합니다. 비교 계정이 자기 합성 데이터에 정상 접근하는 기준 경로와 식별 문자열도 정의해야 인증 만료와 인가 차단을 구분할 수 있습니다. 합성 데이터 접근이 가능한 정상 역할과 접근하면 안 되는 비교 역할을 지정합니다. 쿠키 기반 대상 인증이 필요하면 승인된 테스트 쿠키를 사용자 지정 헤더로 제공하되, 자동 로그인·세션 갱신·브라우저 상태 파일 관리 기능으로 오해하지 않습니다.

12. 자산 연동과 자동발견

12.1 연동 유형

관리자 → 연동 관리에서 이름, 유형, 주소, 비밀정보와 JSON 설정을 등록합니다. 연결 테스트로 접근 가능성을 확인한 다음 동기화를 실행합니다.

hunter.

hunter · 예시 환경

지속적인 보안 검증

워크스페이스

🏠 보안 현황

🔑 서비스 자산

🔍 발견 건

🔧 개선 요청

📊 진단 실행

🔗 에이전트 진단

📅 진단 예약

🗺️ 영향 관계도

🔍 권한 검증

📄 보고서

🔒 보안 기여

🔗 AI 분석 도우미

서비스 관리

연동 관리

오프라인 운영 준비

서비스 관리자

서비스 관리자

서비스 관리 > 연동 관리

🔍 빠른 이동 Ctrl K 2026년 9월 12일 서

ADMINISTRATION

연동 관리

API, 데이터베이스, 웹hook과 기존 진단 엔진을 유연하게 연결합니다.

</> REST API

ITAM · ITSM · 서비스 카탈로그

</> 데이터베이스

PostgreSQL 위기 전용 수집

</> 이벤트 웹hook

백로 · 소스 변경 기반 재진단

</> 진단 엔진

Trivy · Nuclei · ZAP · SARIF

연동 목록 4

🔍 이름, 서비스, 상태 검색

방식

📄 전체

4개 결과 / 조회 4개

🔍 저장한 보기

📄 표 표시 설정

열 제목을 눌러 정렬할 수 있습니다.

이름	방식	연결 주소	사용	변경 일시	
배포 변경 웹hook	웹hook	—	활성	09. 11. 오전 07:08	...
ITSM 개선 요청 발신	REST API	https://itsm.example.internal/ap...	비활성	09. 11. 오전 07:08	...
PostgreSQL 자산 대장	PostgreSQL	사내 자산 DB	비활성	09. 11. 오전 07:08	...
ITAM 서비스 카탈로그	REST API	https://itam.example.internal/a...	비활성	09. 11. 오전 07:08	...

4건 · 1~4 표시

25개씩

유연한 연동을 위한 설정 안내

연동 비밀정보는 암호화되어 저장됩니다. 수집한 자산은 발견 후보로 등록되며 자동으로 진단 승인되지 않습니다.

REST API PostgreSQL 웹hook · API

```
{
  "items_path": "data.services",
  "mapping": {
    "name": "service_name",
    "url": "endpoint",
    "team": "owner_team"
  }
}
```

hunter · 지속적인 보안 검증 플랫폼

🔒 사내 환경을 위한 안전한 연동

유형	사용 목적	제한
REST API	ITAM·서비스 카탈로그 자산 수집	등록한 API와 필드 매핑에 따른 가져오기
PostgreSQL	사내 자산 테이블·뷰 수집	별도 읽기 전용 계정과 조회 SQL
웹hook	변경 이벤트와 외부 시스템 호출 연결	Hunter 권한 검사와 기존 승인 범위 적용
스캐너 결과	승인된 도구 결과 수입	도구 바이너리를 직접 설치·실행하지 않음

12.2 REST 필드 매핑 예시

```
{
  "items_path": "data.services",
  "mapping": {
    "name": "service_name",
    "url": "endpoint",
    "team": "owner_team"
  }
}
```

원본 JSON 구조에 맞는 목록 경로와 필드 매핑을 설정합니다. 외부 필드명이 바뀌면 매핑을 수정하고 소수 데이터를 먼저 확인합니다. 이름·URL·환경·조직을 변환하는 전용 사내 API 어댑터를 둘 수도 있습니다.

12.3 PostgreSQL 연동 예시

PostgreSQL 연동의 비밀번호 입력에 DSN을 넣으면 암호화하여 저장합니다. 계정은 필요한 뷰만 읽을 수 있도록 제한하고 운영 핵심 테이블 전체 권한을 부여하지 않습니다.

```
{
  "query": "SELECT name, url, team FROM hunter_service_catalog LIMIT 500",
  "mapping": {
    "name": "name",
    "url": "url",
    "team": "team"
  }
}
```

SELECT 쿼리, 읽기 전용 트랜잭션, 5초 시간 제한과 최대 500행을 적용합니다. 이 제한과 별개로 원본 DB의 계정 권한을 최소화합니다. Oracle·MSSQL·MySQL 전용 드라이버를 번들한 것은 아닙니다. 이러한 시스템은 사내 REST 어댑터, PostgreSQL 중계 뷰 또는 가져오기 API로 연결합니다.

12.4 발견 후보 검토

동기화한 자산은 **자동발견 후보**에서 확인합니다. 신규 서비스인지, 담당 조직과 URL이 정확한지 검토한 뒤 서비스 자산으로 등록합니다. 후보 발견 자체가 네트워크 진단 승인이 되지 않습니다.

hunter.

hunter · 예시 환경
지속적인 보안 검증

보안 현황

서비스 자산

발견 건

개선 요청

진단 실행

에이전트 진단

진단 예약

영향 관계도

권한 검증

보고서

보안 기여

AI 분석 도우미

서비스 관리

연동 관리

자산 발견

오프라인 운영 준비

서비스 관리자

서비스 관리 > 자산 발견

빠른 이동 Ctrl K

2026년 9월 12일

서

ADMINISTRATION

자산 발견

외부 시스템에서 수집한 신규 자산을 확인하고 서비스 등록 후보를 관리합니다.

+ 자산 후보 등록

자산 후보 목록 1

이름, 서비스, 상태 검색

상태

전체

1개 결과 / 조회 1개

저장한 보기

표시 설정

열 제목을 눌러 정렬할 수 있습니다.

이름 ↑↓	주소 ↑↓	출처 ↑↓	상태 ↑↓	등록 일시 ↑↓	
신규 인사 서비스 https://hr.example.internal	https://hr.example.internal	—	탐지 후보	09. 11. 오전 07:08	...

1건 · 1-1 표시

25개씩

hunter · 지속적인 보안 검증 플랫폼

© 사내 환경을 위한 안전한 연결

ITAM, DNS, Ingress, Route, Harbor, GitLab 등은 그 정보를 제공하는 사내 API·DB와 연결합니다. 각 제품에 대한 완성된 전용 인증·페이징·이벤트 변환 커넥터가 있다고 가정하지 않습니다.

13. 워커, 진단 예약과 변경 이벤트

13.1 망별 워커

관리자 → 워커·실행 이벤트에서 워커의 상태, 최근 생존 시각, 담당 망과 활성화 여부를 관리합니다.

The screenshot displays the 'hunter' administration interface. The left sidebar contains navigation links such as '진단 실행', '에이전트 진단', '진단 예약', '영향 관계도', '권한 검증', '보고서', '보안 기여', 'AI 분석 도우미', '서비스 관리', '연동 관리', '자산 발견', '실행 정책', '진단 허용 범위', '진단 인증', '워커 · 실행 이벤트', '오프라인 운영 준비', and '서비스 관리자'. The main content area is titled 'ADMINISTRATION' and '워커 · 실행 이벤트'. It includes a search bar, a dropdown for '전체', and a table with columns: 이름, 상태, 망 구분, 사용, and 최근 응답. The table lists two workers: '내장 제한 진단 워커' (온라인) and '내장 제한 진단 워커' (오프라인). Below the table, there is a section for '변경 이벤트 이력' which shows no events.

이름	상태	망 구분	사용	최근 응답
내장 제한 진단 워커	온라인	—	활성	—
내장 제한 진단 워커	오프라인	—	비활성	—

제어 서버의 기본 워커 또는 별도 망의 워커를 사용할 수 있습니다. 워커 전용 실행은 같은 서비스 이미지를 사용하며 HTTP 관리 포트를 열지 않습니다. 같은 PostgreSQL과 같은 네 가지 환경변수로 실행합니다.

```
docker run -d --name hunter-worker-dmz \
  --env-file .env \
  --read-only --tmpfs /tmp:rw,noexec,nosuid,size=64m \
  --cap-drop ALL --security-opt no-new-privileges:true \
  hunter:v1.3.0 --worker-only --worker-id worker-dmz
```

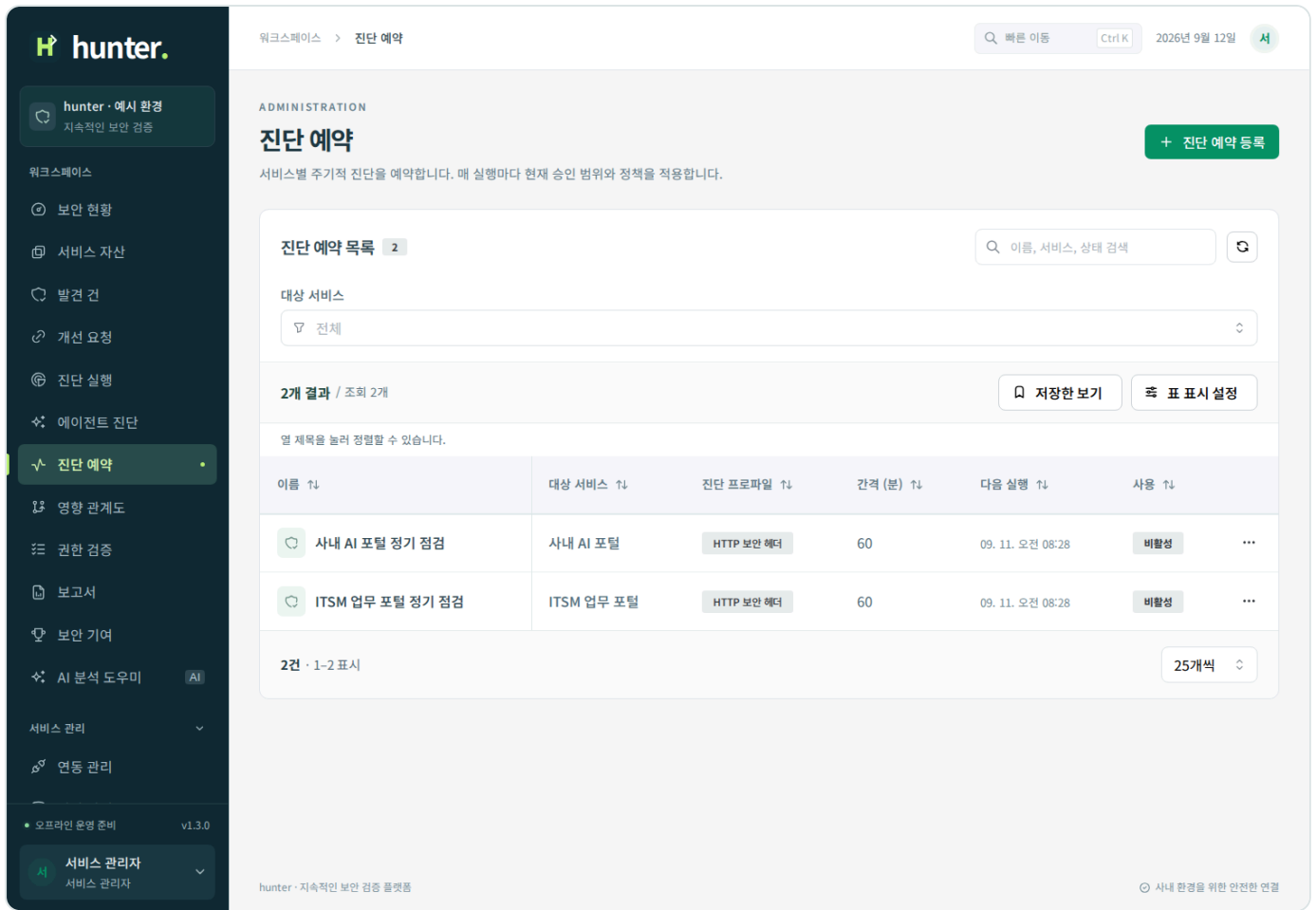
워커 ID는 안정적이고 고유한 값을 사용합니다. 새 외부 워커는 자동 등록되지만 기본 비활성 상태이므로 관리자가 담당 망을 지정하고 활성화해야 합니다. 망 이름은 서비스의 망 값과 **정확히 일치**해야 합니다. 별표 와일드카드는 지원하지 않습니다. 기본 워커의 빈 망 값은 분류되지 않은 서비스만 대상으로 합니다.

각 망의 실제 방화벽·라우팅 정책으로 워커가 승인된 대상과 PostgreSQL에만 접근하도록 구성합니다. 같은 DB에 접근할 수 없는 완전 분리망 사이를 자동 연결하지 않습니다. DB 자격 증명이 있는 워커는 신뢰된 실행 구성요소이므로 일반 사용자에게 워커 실행 호스트의 관리 권한을 제공하지 않습니다.

Go 전용 HTTP transport, 요청 예산과 정책 검사를 사용하며 외부 스캐너의 임의 프로세스를 실행하지 않습니다. 작업 임대·생존 확인과 취소 처리는 PostgreSQL에서 관리합니다. 관리자가 워커를 비활성화하면 신규 실행을 제한하고 실행 상태도 재검사합니다.

13.2 주기적 예약

진단 예약에서 서비스, 프로파일, 범위, 시나리오(필요한 경우), 실행 간격, 첫 실행 시각과 활성 여부를 저장합니다. 간격은 5~10,080분입니다.



제어 서버의 스케줄러가 예약을 처리하고 실제 워커는 같은 작업 큐에서 가져갑니다. 매 실행마다 현재 계정·API 키 권한과 서비스 승인, 유효 범위 및 정책을 확인합니다. 같은 예약 회차를 중복 생성하지 않고 장애 후 놓친 과거 회차를 대량 재실행하지 않습니다. 팀장 검토가 켜져 있으면 예약 진단에도 동일한 흐름을 적용합니다.

13.3 변경 이벤트

배포, Git 변경, 이미지 변경, IAM 변경 이벤트를 기록하고 기존 승인 서비스에 진단을 요청합니다. 웹훅 호출에는 연동 관리 권한이 필요하며 진단까지 요청하려면 scans:write 권한도 필요합니다.

이벤트가 Git 변경이라고 해서 변경 파일 SAST 엔진이 자동 실행되는 것은 아닙니다. 실제 실행은 선택한 프로파일과 현재 정책에 따릅니다.

13.4 개선 요청을 ITSM·개발 플랫폼으로 발송

REST 연동에 direction을 outbound로 설정하고 외부 API에 맞는 JSON template을 작성합니다. 연동 비밀값은 외부 API의 Bearer 인증에 사용합니다.

```
{
  "direction": "outbound",
  "template": {
    "title": "{{finding.title}}",
    "description": "{{finding.description}}",
    "suggested_fix": "{{finding.remediation}}",
    "patch": "{{remediation.patch}}",
    "hunter_reference": "{{remediation.id}}"
  }
}
```

개선 요청에서 발견 건과 이 연동을 선택하고 초안을 작성한 후 명시적으로 발송합니다. 서버는 설정한 주소로 POST를 수행합니다. 티켓·PR API에 필요한 저장소, 브랜치, 프로젝트 필드 등은 조직의 API 문서에 맞춰 템플릿에 넣습니다.

The screenshot displays the Hunter v1.3.0 web application interface. The sidebar on the left contains navigation links for various features. The main panel is titled '개선 요청' (Improvement Request) and includes a search bar, a dropdown for '상태' (Status) set to '전체' (All), and a table of requests. The table has columns for '이름' (Name), '연결 발견 건' (Linked Finding), '상태' (Status), and '변경 일시' (Change Date). A single row is shown with the title '공통 인증 권한 검사 개선' and status '초안'. Below the table, there are pagination controls showing '1건 · 1-1 표시' and '25개씩'.

발송은 Hunter 개선 ID를 기반으로 Idempotency-Key를 제공합니다. 상태가 sending·sent·uncertain이면 자동으로 재전송하지 않으며, 불확실한 응답은 외부 시스템에서 생성 여부를 확인해야 합니다. 외부 API도 멍등성 키를 지원하는지 확인하세요.

성공 응답의 외부 ID·URL은 설정한 응답 필드에 맞게 연결합니다. 자동 병합·배포는 수행하지 않습니다.

14. AI 설정과 스트리밍

14.1 사내 AI 연결

서비스 설정 → AI 분석에서 다음을 설정합니다.

항목	예시
Base URL	http://llm.internal:8000/v1
모델	사내 서버에 등록된 실제 모델 ID
API 키	사내 서버가 요구하는 키, 비밀값으로 저장
최대 출력 토큰	8192 등 모델이 지원하는 실제 한도
컨텍스트 창	입력과 출력을 합산한 한도, 최대 262144
활성화	연결 준비 후 켜기

요청은 OpenAI 호환 `/chat/completions` 로 전송하며 `stream: true` 를 기본으로 사용합니다. UI도 SSE의 delta를 즉시 표시합니다. 프록시와 사내 AI gateway에서 스트리밍을 유지하고 응답 버퍼링을 끕니다.

14.2 256K 처리의 의미

최대 출력 토큰과 컨텍스트 창 설정은 각각 최대 262,144까지 허용합니다. 실제 입력·출력 총합과 모델별 출력 상한은 AI 공급 서버의 정책을 따라야 합니다. 예를 들어 컨텍스트가 262,144여도 모델 최대 출력이 32,768이면 출력 값을 그 이하로 설정해야 합니다.

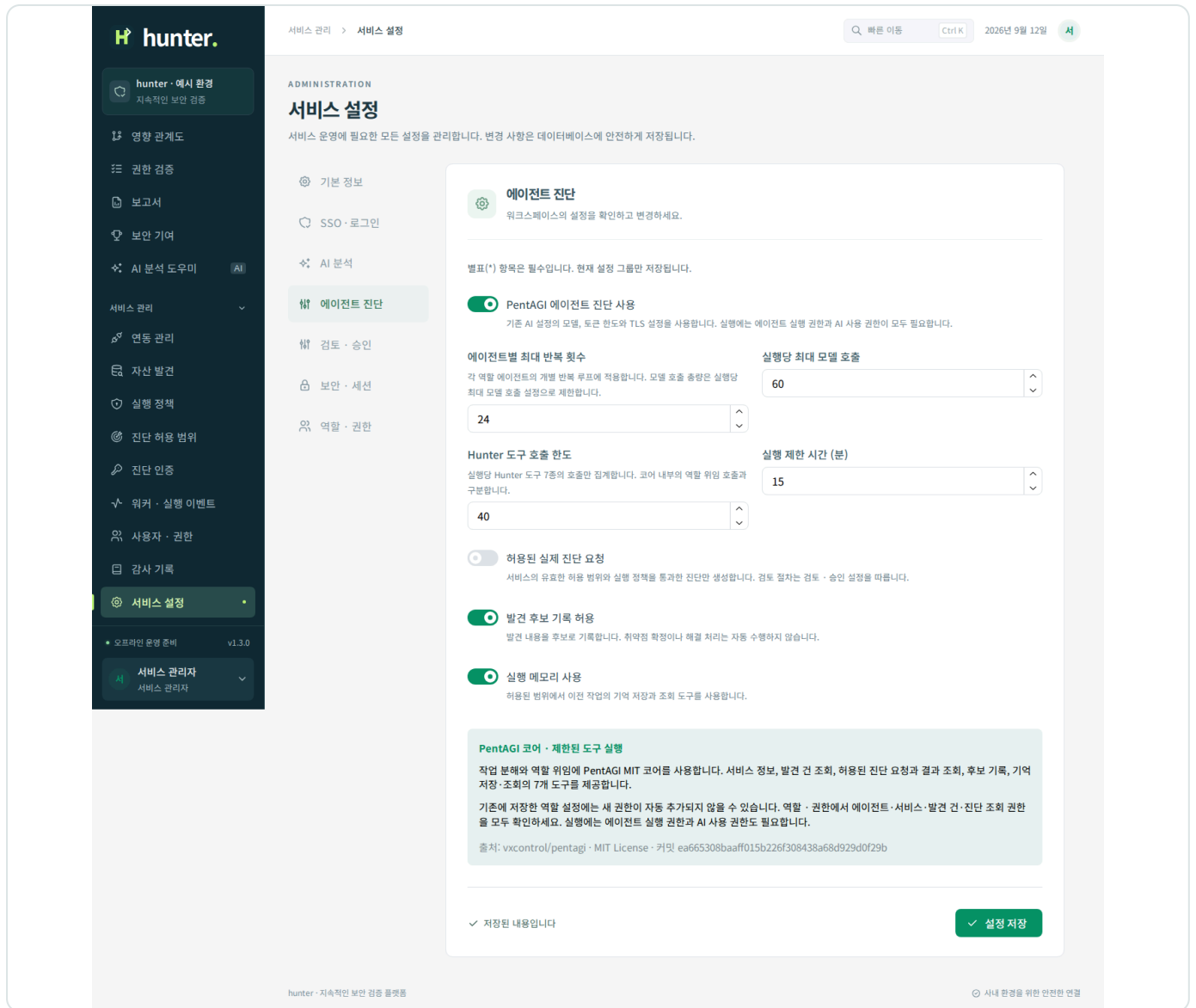
Hunter는 보수적인 UTF-8 바이트 기반 입력 예산으로 과도한 요청을 제한하며, 정확한 모델 토큰 계산과 최종 한도 검사는 공급 서버가 담당합니다. 긴 증거와 소스는 필요한 부분으로 나누고 비밀값을 제거한 뒤 전달합니다.

AI 분석 도우미는 분석 제안을 제공합니다. 에이전트 기능에서 도구를 사용하더라도 모델 출력이 실행 정책, 사용자 역할, API 권한이나 범위 승인을 변경하지 않습니다. 대상 문서와 응답에 포함된 지시문을 도구 실행 명령으로 신뢰하지 않습니다.

14.3 에이전트 코어 활성화

서비스 설정 → 에이전트 진단에서 기능과 실행 한도를 관리합니다. 먼저 AI 분석 설정에 사내 모델의 주소와 인증, 모델명·컨텍스트·출력 한도를 저장합니다. 에이전트는 해당 연결을 사용하므로 모델과 게이트웨이가 구조화된 도구 호출을 지원해야 합니다.

설정	기본값	의미
활성화 (<code>enabled</code>)	꺼짐	에이전트 실행 기능 허용
에이전트별 최대 반복 횟수 (<code>max_iterations</code>)	24	각 역할의 원본 에이전트 대화 처리 반복 상한, 설정 범위 6~100
모델 호출 (<code>max_model_calls</code>)	60	한 실행의 모델 요청 상한, 설정 범위 5~200
Hunter 도구 호출 한도 (<code>max_tool_calls</code>)	40	한 실행의 일곱 Hunter 도구 호출 상한, 내부 역할 위임 제외, 설정 범위 1~200
제한 시간 (<code>timeout_minutes</code>)	15분	한 실행의 시간 한도, 설정 범위 1~60분
진단 허용 (<code>allow_diagnosis</code>)	꺼짐	에이전트의 진단 요청 도구 사용 허용
후보 등록 (<code>allow_candidates</code>)	켜짐	발견 후보 생성 허용
기억 기능 (<code>memory_enabled</code>)	켜짐	허용된 맥락 저장·검색 사용

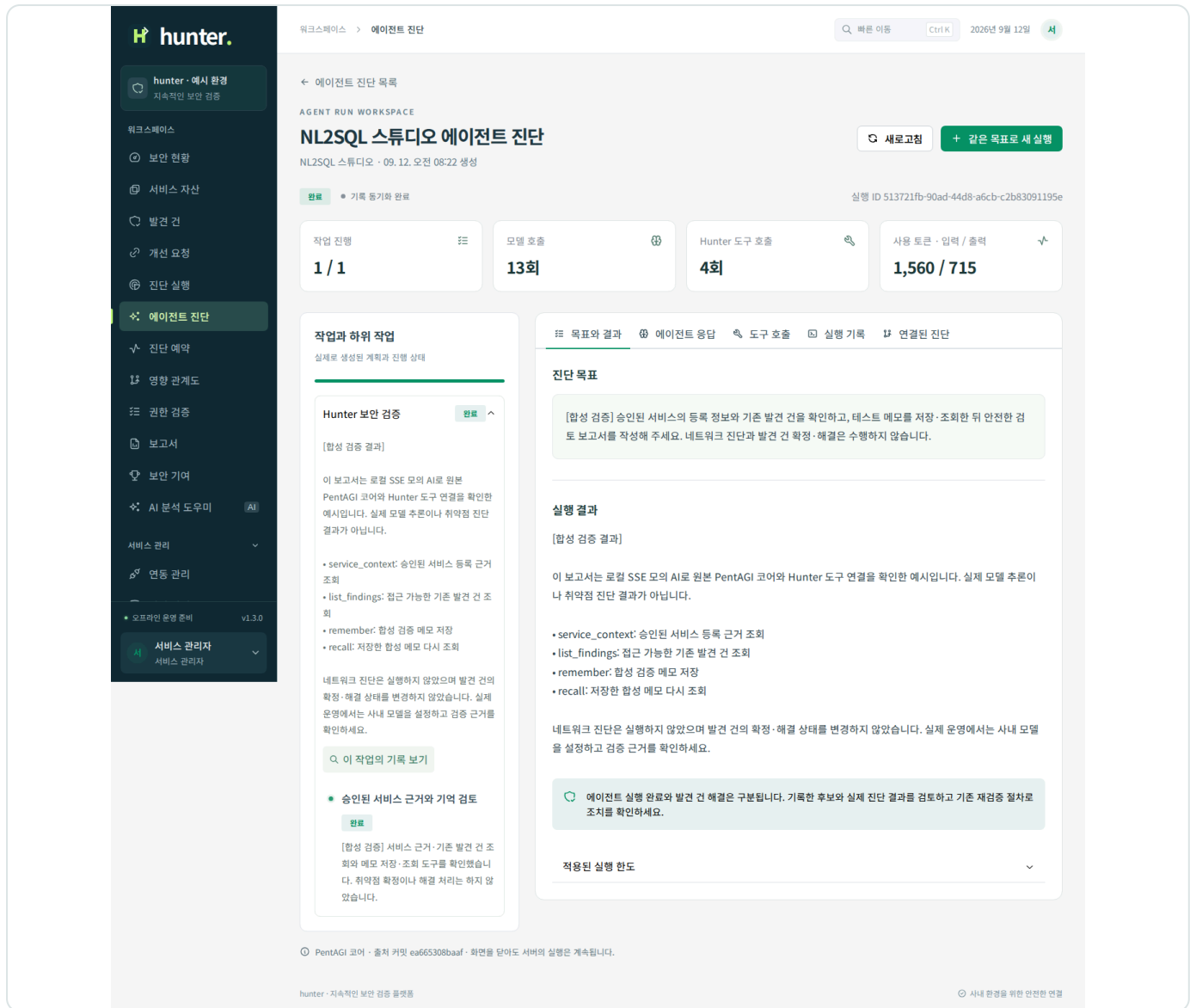


실행 기록에 발견 건과 진단 결과가 포함될 수 있으므로 목록·상세·이벤트 조회에는 `agents:read`, `services:read`, `findings:read`, `scans:read` 네 권한이 모두 필요합니다. 실행 생성에는 `agents:write` 와 `ai:use` 를 추가로 요구합니다. 역할과 개인 키의 현재 권한, 서비스 접근 범위를 함께 검사합니다. 기존 설치에서 역할 권한을 별도 저장했다면 새 권한과 관련 자료 조회 권한이 사용자에게 부여되었는지 확인합니다.

에이전트 생성 단계부터 서비스 승인과 유효 범위가 필요합니다. 사용자가 범위를 지정하지 않으면 서버가 해당 서비스의 유효한 승인 범위를 선택하며, 범위가 없으면 실행하지 않습니다. 진단 허용을 켜도 현재 역할·키 권한, 실행 정책과 긴급 중지 통제는 그대로 적용됩니다. 후보 등록은 취약점 확인이나 해결 상태의 자동 확정이 아닙니다. 기억 저장은 같은 PostgreSQL을 사용하며 별도 벡터 확장이나 Graphiti 서버 설치를 요구하지 않습니다. 메모리는 사용자·서비스별 100개까지 저장합니다. 에이전트 실행 목록은 접근 가능한 최신 1,000건을 표시하고 사용자당 진행 중인 실행은 최대 3개입니다.

14.4 원본 코어와 Hunter 연결 범위

고정된 PentAGI 원본의 계획·위임·실행·재시도·성찰·대화 요약 코어를 사용하고, 실제 행위는 서비스 조회·발견 건 조회·진단 요청·진단 결과 조회·후보 등록·기억 저장·기억 검색의 일곱 Hunter 도구로 연결합니다. 원본 Docker 런타임, 클라우드 검색과 원격 텔레메트리는 시작하지 않습니다. 기존 일반 PostgreSQL DSN과 네 환경변수, 서비스 이미지 하나로 배포합니다.



에이전트 목록과 상세 화면에서 작업, 도구 호출, 실시간 이벤트와 종료 이유를 확인합니다. 사용자의 중지 요청과 설정 한도는 실행을 제한하며, 중지는 이미 끝난 외부 요청이나 저장된 자료를 자동 복원하지 않습니다. 다시 시도는 이전 실행을 덮어쓰는 대신 새 실행 이력으로 관리합니다. 기존 비공개 대화 이력을 이어서 재개하는 기능은 제공하지 않으며, 같은 실행 ID를 다시 실행하지 않습니다.

모델에 제공하는 서비스·발견 정보와 도구 결과는 비신뢰 입력으로 취급합니다. 모델 응답으로 사용자 권한을 확대하거나 진단 정책을 바꾸지 않습니다. 사내 게이트웨이가 응답을 버퍼링하지 않는지, 실패·취소·재시도에서도 현재 권한과 실행 한도가 적용되는지 운영 반영 전에 확인합니다.

코어 통합 출처와 라이선스에서 원본 커밋과 라이선스 근거를 확인할 수 있습니다. 이미지 안에는

/usr/share/licenses/hunter/ 에 라이선스 원문과 출처 목록을 포함합니다. Go·코어·폰트 고지는

dependencies.json , 프론트엔드 npm 고지는 npm/manifest.json 과 npm/components/ 에 따로 기록합니다.

Docker 빌드와 CI가 설치된 의존성의 고지를 수집하며, 필수 고지나 고정 출처 근거가 누락되면 빌드를 실패시킵니다.

15. REST API와 MCP

15.1 API 인증

개인 키를 Bearer 헤더에 넣습니다. 브라우저 세션으로 상태 변경 API를 직접 호출할 때는 X-Hunter-CSRF: 1 과 동일 출처 조건이 필요합니다. 개인 Bearer 키 인증은 CSRF 헤더 대상이 아닙니다.

```
curl 'https://hunter.internal/api/findings' \
  -H 'Authorization: Bearer YOUR_HUNTER_KEY'
```

경로	용도
GET /api/health	상태 · 버전
GET /api/openapi.json	OpenAPI 명세
/api/services	서비스 조회 · 등록 · 수정
/api/findings	발견 건 관리
POST /api/imports	외부 진단 결과 수입
/api/scans	진단 요청 · 조회
POST /api/scans/{id}/cancel	진단 취소
POST /api/scans/{id}/approve	활성화된 검토크롬 승인 · 반려
/api/events	변경 이벤트
POST /api/emergency-stop	긴급 중지 · 해제
GET /api/reports/export?format=json	보고서 내보내기
/api/keys	개인 키 관리
POST /api/ai/chat	AI SSE 스트리밍
GET·POST /api/agent-runs	에이전트 실행 목록 · 생성
GET /api/agent-runs/{id}	에이전트 실행 상세
GET /api/agent-runs/{id}/events	실시간 SSE 이벤트
POST /api/agent-runs/{id}/stop	해당 실행 중지 요청

모든 자원이 모든 HTTP 메서드를 제공하는 것은 아닙니다. 위커 · 승인 이력 등은 직접 CRUD 대상이 아닌 경우가 있으며 실행 중 서비스의 OpenAPI와 API 오류 메시지를 확인합니다.

15.2 MCP 연결

HTTP 엔드포인트는 `/mcp` 입니다. MCP 프로토콜 2025-06-18과 2025-11-25에 대한 초기화 협상을 지원하고, 개인 API 키 인증으로 사용합니다. OAuth 자동 등록과 브라우저 인증을 요구하는 MCP 클라이언트는 그대로 연결되지 않을 수 있습니다.

```
{
  "url": "https://hunter.internal/mcp",
  "headers": {
    "Authorization": "Bearer YOUR_HUNTER_KEY"
  }
}
```

위 예시는 주소와 헤더를 보여주는 개념 설정입니다. 각 MCP 클라이언트의 실제 설정 파일 문법에 맞춰 적용합니다. 도구는 `hunter_list_services`, `hunter_list_findings`, `hunter_request_scan` 이며 REST와 같은 권한·정책을 적용합니다.

16. 감사 기록과 증거 관리

관리자 → 감사 기록에서 수행자, 작업, 대상과 시각을 확인합니다. 주요 설정·계정·키·진단 변경을 조사할 때 사용합니다.

감사 목록에서 사용자·작업·대상을 검색하고 작업·사용자·기간 필터로 범위를 좁힙니다. 일시 열로 시간순을 바꾸고 페이지당 표시 수와 페이지 이동을 사용합니다. 검색 조건은 조회 권한이나 서버의 자료 보존·조회 한도를 늘리지 않습니다.

서비스 관리 > 감사 기록

Q 빠른 이동 Ctrl K 2026년 9월 12일 서

AUDIT & TRACEABILITY

감사 기록 새로고침

누가, 언제, 어떤 작업을 수행했는지 확인합니다. 민감한 인증 정보는 기록에서 제외됩니다.

활동 기록 117 Q 사용자 · 작업 · 대상 · 상세 검색 모든 작업 모든 사용자 전체 기간

117개 결과 / 조회 117개 Q 저장한 보기 Q 표시 설정

표 안에서 스크롤을 더 확인하세요. 열 제목은 고정됩니다.

수행 일시 ↓	사용자 ↑	작업 ↑	대상 ↑	상세
09. 12. 오전 10:36	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:28	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:28	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:26	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:25	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:25	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:24	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기
09. 12. 오전 10:23	admin	auth.login	3d0cafde-bdb5-448e-b4c6-70d003d499b1	기록 보기

117건 · 1-25 표시 25개씩 < 1 2 3 4 5 >

hunter · 지속적인 보안 검증 플랫폼 © 사내 환경을 위한 안전한 연결

감사 기록은 애플리케이션 DB에 저장되므로 독립적인 WORM 저장소나 외부 SIEM의 변조 방지 증거를 대체하지 않습니다. 규정상 보존 요건이 있으면 DB 접근 통제, 백업·복제와 별도 로그 수집을 조직 정책으로 구성합니다.

증거는 필요한 정보를 마스킹하여 저장하고, 암호화된 데이터도 접근 권한이 있는 API 응답에서는 사용자가 읽을 수 있다는 점을 고려합니다. 자동 마스킹이 모든 개인정보를 탐지한다는 전제로 운영하지 않습니다. 현재 버전에서 자동 보존 기간 삭제 작업과 독립 오브젝트 저장소는 제공하지 않으므로 보존·파기 절차를 별도로 관리합니다.

에이전트의 사용자 화면 이벤트, 서비스 메모리와 발견 증거는 Hunter 암호화 저장소를 사용합니다. PentAGI 코어 호환 스키마의 대화 이력·작업·사용량 테이블에는 별도의 필드 암호화를 적용하지 않습니다. 전달 전에 질문과 도구 결과를 마스킹하지만

모델의 후속 처리에 필요한 비공개 추론이 포함될 수 있으며, 이 기록은 일반 UI 이벤트에 노출하지 않습니다. 코어 스키마까지 포함한 DB 접근 통제와 백업 보호가 필요합니다. 모델 API 키는 대화나 코어 기록에 넣지 않습니다.

16.1 위험 수용 만료와 재검토

위험 수용은 사유와 미래의 만료 일시를 요구합니다. 만료 시각을 지나면 대시보드는 해당 발견 건을 즉시 열린 위험·심각한 위험·보안 부채 집계에 다시 포함합니다. 제어 서버의 분 단위 유지보수 작업은 상태를 탐지 후보로 바꾸고 `finding.acceptance_expired` 감사 기록을 같은 DB 작업으로 남깁니다.

이미 만료 처리한 항목은 다음 작업에서 다시 전환하지 않습니다. 유지보수 시점 전의 짧은 구간에도 대시보드에서 만료 항목을 제외하지 않으므로 수용 기간이 끝난 위험이 계속 숨겨지지 않습니다.

17. 백업과 복구

17.1 백업 대상

- PostgreSQL 전체 DB: 사용자, 설정, 암호화된 비밀·증거, 자산, 발견 건, 작업, 감사
- 현재 DB에 대응하는 `ENCRYPTION_KEY`
- 배포에 사용한 이미지 버전과 체크섬
- Compose 설정, TLS 프록시 설정, 인증서와 비밀 저장소의 복구 절차

DB 백업만으로 암호화된 비밀을 복원할 수 없습니다. 키를 잃으면 데이터의 암호화 부분을 복구할 수 없습니다. DB와 키는 권한과 보관 위치를 분리합니다.

17.2 일관된 백업

1. 긴급 중지를 켜서 새 진단과 진행 진단을 중지합니다.
2. 유지보수 시간을 공지하고 Hunter 컨테이너를 정지하여 변경을 멈춥니다.
3. 조직의 PostgreSQL 백업 도구로 전체 DB를 백업합니다.
4. 이미지 태그·체크섬과 암호화 키의 안전한 보관 여부를 기록합니다.
5. 서비스를 시작하고 상태 확인 후 긴급 중지를 해제합니다.

다음 명령은 PostgreSQL 클라이언트가 설치된 백업 실행 환경에서 연결 변수가 안전하게 제공되었다는 전제의 예시입니다.

```
docker compose stop hunter

pg_dump --dbname="$POSTGRES_DSN" --format=custom --file=hunter-backup.dump

docker compose up -d
```

명령 이력이나 프로세스 목록의 자격 증명 노출이 우려되면 조직의 PostgreSQL service 파일·비밀 주입 방식을 사용합니다. 백업 파일을 암호화하고 복구 테스트 없이 정상 백업으로 판정하지 않습니다.

17.3 복구

1. 복구 대상에 별도 DB를 생성합니다.
2. 백업을 복원하고 원본과 동일한 암호화 키를 안전하게 제공합니다.
3. 백업에 대응하는 Hunter 버전 이미지를 불러옵니다.
4. DSN을 복구 DB로 지정하여 실행합니다.

5. 로그인, 비밀번호 설정 해독, 서비스·발견 건·감사 기록을 확인합니다.
6. 검증계의 승인된 작은 진단으로 기능을 확인한 뒤 운영 전환합니다.

```
pg_restore --dbname="$RESTORE_POSTGRES_DSN" --no-owner hunter-backup.dump

docker load -i hunter-v1.3.0.tar.gz

docker compose up -d
```

새 DB를 위한 자동 초기 관리자 생성과 기존 DB 복원 절차를 혼동하지 않습니다. 복원한 DB에 사용자가 있으면 bootstrap 환경변수로 계정을 다시 생성하지 않습니다.

17.4 마스터 암호화 키 변경

개인 API 키 회전과 `ENCRYPTION_KEY` 변경은 다릅니다. 현재 버전은 전체 DB 비밀을 새 마스터 키로 재암호화하는 온라인 마이그레이션 도구를 제공하지 않습니다. 운영 중 환경변수만 새 키로 바꾸면 서비스가 시작되지 않습니다. 이 키의 변경이 필요하다면 전체 백업과 별도로 검증된 재암호화 마이그레이션을 준비해야 합니다.

18. 업그레이드와 롤백

1. 릴리즈의 변경 내용과 실제 제공 범위를 검토합니다.
2. 기존 이미지와 DB 백업, 암호화 키를 확보합니다.
3. 검증계에서 복원한 DB로 새 버전을 먼저 실행합니다.
4. 승인된 작업의 실제 결과, OIDC·키·AI·연동과 화면을 점검합니다.
5. 유지보수 창에서 진단 중지 후 새 이미지로 전환합니다.
6. `compose.yaml`의 이미지 태그를 새 버전으로 바꿉니다.
7. 상태·버전과 주요 화면을 확인하고 진단을 다시 허용합니다.

시작 시 필요한 DB 스키마를 자동으로 준비합니다. 스키마 변경이 있는 업그레이드에서 이전 바이너리만 다시 띄우면 호환되지 않을 수 있습니다. 롤백은 이전 이미지와 대응하는 DB 백업을 함께 복원하는 절차로 검증합니다.

19. 운영 장애 점검

증상	점검 순서
컨테이너 즉시 종료	네 가지 환경변수, DSN, DB 접근·권한, 32바이트 base64 키
기존 DB 복호화 실패	원래 ENCRYPTION_KEY 확인, 임의 재생성 금지
로그인 반복 이동	공개 URL, HTTPS 쿠키, 프록시 Host, 브라우저 쿠키
로그인 429 응답	사용자명·IP 시도 횟수, 동시 처리 한도, 공유 프록시 IP
OIDC callback 실패	정확한 redirect URI, issuer, secret, 사내 CA, 시간 동기화
SSO 후 권한 부족	신규 사용자 기본 역할, 실제 사용자 역할
API 키 인증 실패	유효 기간, 회전·폐기 여부, 계정 비활성화
HTTP 진단 거부	서비스 승인, 범위·CIDR·호스트·경로·만료, 정책
작업이 멈춤	워커 생존, 임대 상태, 긴급 중지, 대기 승인
AI가 한 번에 표시됨	프록시·gateway 버퍼링과 SSE 전달
AI 토큰 오류	모델 실제 컨텍스트·최대 출력, 입력 크기
DB 연동 실패	읽기 계정 권한, SQL, 연결 문자열, TLS, 제한
새로고침 경로 오류	Go SPA 경로 전달, 프록시 rewrite 설정

장애 재현 시각, 버전, 대상 작업 ID와 마스킹한 오류를 남깁니다. 서비스 로그와 DB 오류의 원문에는 내부 주소가 포함될 수 있으므로 필요한 사람에게만 공유합니다.

20. 개발·문서 재생성·릴리즈

20.1 로컬 빌드

빌드 구간에는 Go 1.26.5 이상, Node.js 26과 npm 패키지·Go 모듈 접근이 필요합니다. 빌드 시 인터넷 요구와 배포 후 오프라인 운영은 별개입니다.

```
npm --prefix web ci
npm --prefix web run build
mkdir -p internal/webassets/dist
cp -a web/dist/. internal/webassets/dist/
go test ./...
go build ./cmd/hunter
```

20.2 가이드 재생성

문서 원본은 `docs/guides/*.md` 이고 HTML·PDF에는 같은 본문과 이미지가 들어갑니다.

```
npm --prefix docs ci
npm --prefix docs exec -- playwright install chromium
node scripts/render-guides.mjs
node scripts/check-docs.mjs
```

실제 화면 캡처는 `docs/images` 에 저장합니다. 운영 데이터·비밀값이 담긴 화면은 공개 문서로 사용하지 않습니다. 가이드의 이미지가 모두 존재해야 PDF를 정상 생성할 수 있습니다.

20.3 릴리즈 규칙

```
bash scripts/release.sh 1.3.0
```

스크립트는 `VERSION` 일치 여부를 확인하고 Docker 이미지를 만든 뒤 `docker image save | gzip` 으로 `dist/hunter-v1.3.0.tar.gz` 를 생성합니다. 파일에는 `hunter:v1.3.0` 서비스 이미지 하나만 들어갑니다.

GitHub Actions는 main에서 빌드·테스트를 수행하고 버전 태그에서 서비스 이미지 릴리즈를 생성합니다. 문서는 별도 GitHub Pages workflow에서 docs 를 배포합니다. GitHub 저장소의 Pages 배포 소스는 **GitHub Actions**로 설정합니다.

21. 참고 문서

- [Docker 이미지 저장](#)
- [GitHub Pages 사용자 지정 workflow](#)
- [Keycloak OIDC 엔드포인트](#)
- [PostgreSQL 백업과 복원](#)
- [Playwright PDF 생성](#)

[사용자 일상 업무 가이드로 이동](#)

Hunter v1.3.0 · 실제 화면과 함께 보는 사내 보안 검증 가이드